

Executive Summary

Enterprise GRC, Risk & Resilience Program

SecurityGroup101 | Enterprise GRC Program

Prepared By: Maxine Jones, GRC Analyst | Reviewed By: Chief Information Security Officer

Version 1.0 | Classification: Confidential – Internal Use

SecurityGroup101 is a fintech company providing cloud-based payment processing and financial data analytics. This program was launched to replace fragmented risk processes and inconsistent controls with a unified Governance, Risk, and Compliance (GRC) function aligned to NIST, ISO/IEC 27001:2022, COBIT 2019, GLBA, PCI DSS v4.0, FFIEC, and SOX.

93 Annex A Controls Assessed	3 Regulatory Frameworks	\$500K Highest Single-Asset ALE	Remediated Vendor Risk Gap
--	-----------------------------------	---	--------------------------------------

Four Workstreams

Workstream	Summary
Quantitative Risk Assessment	10-asset register using SLE/ARO/ALE modeling (NIST SP 800-30); Customer Data and Employee Workstations are the top two risk-tier assets.
Regulatory Compliance	GLBA, PCI DSS v4.0, and FFIEC gap analyses crosswalked to NIST CSF, ISO 27001, and COBIT 2019.
Disaster Recovery & Continuity	Tiered DRP/BCP (NIST SP 800-34) with RTO/RPO targets and a five-part testing matrix.
Enterprise GRC Program	Governance model, unified control catalog, and an 18-month phased roadmap (currently Phase 1–2).

Risk Heatmap at a Glance

Asset(s)	Risk Level
Customer Data	Critical
Employee Workstations / Financial Records / Backup Systems	High
Proprietary Software / Cloud Storage / Dev Environment	Medium
Database Server / Email Server / Website	Moderate

Recent Additions: Closing Identified Gaps

The GLBA Gap Analysis identified the absence of a formal third-party risk management program as a critical blind spot. That gap has been remediated with a new Third-Party Vendor Risk Assessment Program, including intake questionnaires, a criticality tiering model, a documented security finding, and an executive decision memo. A full 93-control ISO/IEC 27001:2022 Statement of Applicability has also been added, giving the program a single source of truth for control status across the organization — 24 Implemented, 39 Partial, and the remainder Draft, Planned, In Progress, Gap, or Not Applicable.

Where to go next: see the repository README for a full document index linking each workstream's markdown source to its consolidated PDF deliverable.